

Tabletop Exercise: Business Email Compromise and Wire Fraud

1. Exercise Overview

Title: Executive Impersonation and Fraudulent Wire Transfer

Scenario Type: Business Email Compromise (BEC) / Payment Fraud

Audience: Executive, operational, treasury, fraud, legal, compliance, communications, and technical response stakeholders

Duration: 60–90 minutes

Format: Facilitated tabletop exercise with phased injects and debriefs

Classification: Internal use only

2. Purpose

This tabletop exercise is designed to test the organization's ability to identify, contain, escalate, and respond to a business email compromise attempt involving executive impersonation and an urgent overseas wire transfer request. The exercise focuses on fraud controls, crisis decision-making, communications, and post-transfer recovery actions.

3. Exercise Objectives

By the end of the exercise, participants should be able to:

1. Validate controls for urgent and high-value payment requests.
 2. Assess whether out-of-band verification and dual authorization procedures are understood and consistently applied.
 3. Test escalation paths between Treasury, Finance, Fraud, Security, Legal, Compliance, and Executive leadership.
 4. Evaluate the organization's ability to respond once a fraudulent transfer has been released.
 5. Review evidence preservation, recall coordination, counterparty engagement, and law-enforcement/regulatory considerations.
 6. Identify gaps in playbooks, training, and executive communications.
-

4. Suggested Participants

Executive / strategic participants

- CFO or delegate

- COO / business leadership representative
- Crisis management lead
- Corporate communications lead
- Legal counsel
- Compliance / regulatory affairs lead

Operational participants

- Treasury operations manager
- Payment operations lead
- Fraud investigations lead
- Relationship / correspondent banking representative
- Business continuity lead

Technical / control participants

- Security operations / incident response lead
 - Email security / messaging administrator
 - Identity and access management representative
 - Insider risk / monitoring representative
 - Records / forensic preservation representative
-

5. Scope

In scope

- Executive impersonation by email
- Payment approval workflow and exceptions handling
- Fraud detection and transaction recall process
- Internal escalation and crisis coordination
- External notifications to correspondent / beneficiary institutions
- Preservation of email, logs, approval evidence, and communications
- Executive, legal, and regulatory decision-making

Out of scope

- Detailed malware reverse engineering
 - Deep forensic validation of endpoint compromise
 - Physical security response
 - Recovery of unrelated infrastructure
-

6. Assumptions

- The organization is a commercial bank with established treasury and high-value payment approval processes.

- High-value and urgent transfer requests require dual authorization and, in some cases, additional verbal or authenticated verification.
 - Email is widely used for internal executive-to-operations communication.
 - The institution has access to legal, fraud, security, and executive escalation channels.
 - The scenario is discussion-based. Participants should respond according to existing roles, authorities, and procedures.
-

7. Rules of Engagement

- This is a no-fault learning exercise.
 - Participants should answer from their real role and current process.
 - There are no perfect answers; the goal is to identify strengths, gaps, dependencies, and decision points.
 - Facilitators may introduce new facts as the scenario evolves.
 - Real-world incidents take precedence over the exercise.
-

8. Scenario Summary

A threat actor conducts a targeted business email compromise campaign against the bank's payment approval process. An employee in a senior finance or treasury-adjacent role receives an email that appears to come from the CFO. The message references a confidential acquisition closing and instructs the recipient to urgently release a large overseas wire transfer to a beneficiary account. The tone emphasizes secrecy, urgency, and executive authority.

Under pressure and with limited ability to verify the request through normal channels, the transaction proceeds through an exception path. Shortly after release, concerns emerge that the request may have been fraudulent. The organization must decide how to contain the damage, initiate a recall, preserve evidence, notify relevant parties, and brief leadership while balancing legal, regulatory, client, and reputational considerations.

9. Threat Context

Threat actor profile

A financially motivated actor uses executive impersonation and social engineering to induce fraudulent wire approval.

Attack pattern

Spoofed or lookalike executive payment instruction invoking urgency and confidentiality to bypass standard controls.

Primary business risk

Financial loss from unauthorized transfer, reputational harm, regulatory scrutiny, and exposure of control weaknesses.

10. Exercise Timeline and Injects

Phase 1 – Suspicious Executive Request

Inject 1

A senior manager in treasury operations receives an email appearing to come from the CFO. The message states that a confidential acquisition closing is occurring today and instructs the manager to immediately release a high-value overseas wire transfer to a newly provided beneficiary. The message emphasizes that timing is critical, that the matter is highly confidential, and that normal communication channels may delay the closing.

What participants know at this stage

- The email appears legitimate at first glance.
- The sender display name matches the CFO.
- The transfer is large, cross-border, and time-sensitive.
- The beneficiary account is unfamiliar or newly introduced.
- The request appears to discourage ordinary verification.

Discussion questions

- What immediate actions should the recipient take before any approval occurs?
- Which payment controls should be triggered by the size, urgency, geography, or beneficiary change?
- Is the request sufficient to justify pausing payment execution?
- What out-of-band verification methods are available and mandatory?
- Who should be informed internally at this stage?
- What evidence should be preserved immediately?

Expected actions

- Halt or place the payment in review pending verification.
- Validate the request using established out-of-band procedures.
- Check whether the sender domain, reply-to, routing, or other email artifacts are suspicious.
- Escalate to Treasury leadership, Fraud, and Security as appropriate.
- Preserve the email, headers, approval trail, and any related chats or calls.

Facilitator notes

Prompt participants to discuss practical friction points: executive pressure, after-hours approvals, confidential deals, unavailable approvers, and whether exception handling is too permissive.

Phase 2 – Pressure, Exception Path, and Transfer Release

Inject 2

The payment is released after a pressured approval path. A participant learns shortly afterward that the CFO denies sending the email. The organization must now decide how to initiate a fraud recall, preserve evidence, notify counterpart institutions, and brief executives. Time is critical because the transfer may soon move through additional accounts.

What participants know at this stage

- The wire has been released.
- The CFO states the message is fraudulent.
- The beneficiary account is outside the bank's normal payment pattern.
- Internal concern rises that this was a BEC-driven wire fraud event.
- The recovery window is narrowing.

Discussion questions

- Who owns incident command now: Treasury, Fraud, Security, Crisis Management, or a joint structure?
- What are the first 15–30 minute actions to maximize the chance of fund recovery?
- Which external institutions must be contacted and in what order?
- When should legal counsel be engaged?
- What evidence must be preserved to support investigation and recovery?
- What thresholds trigger executive notification and crisis governance activation?
- How will the bank manage internal communications while facts are still developing?

Expected actions

- Initiate fraud recall or financial institution recovery procedures immediately.
- Contact beneficiary bank and any correspondent / intermediary institutions.
- Preserve payment records, email records, logs, approvals, beneficiary details, and call records.
- Open a cyber/fraud incident and establish a command structure.
- Notify executive leadership and determine whether broader crisis activation is required.
- Assess whether related accounts, mailboxes, or payment workflows may also be targeted.

Facilitator notes

Push participants on speed versus certainty. Recovery decisions often must be made before complete forensic confirmation. Explore whether the institution has a single coordinated playbook or fragmented fraud and cyber procedures.

Phase 3 – Containment, Investigation, and Wider Exposure Assessment

Inject 3

Initial review indicates the email originated from a spoofed or deceptive source rather than the CFO's legitimate mailbox, but investigators cannot yet rule out mailbox compromise elsewhere in the executive support chain. The bank must determine whether this was a standalone social engineering attempt or part of a broader campaign targeting finance personnel and approval workflows.

What participants know at this stage

- The event may be spoofing, a lookalike domain, or unauthorized use of a related mailbox.
- Similar lure language may have been sent to other finance approvers.
- There is no confirmed endpoint compromise at this time.
- Media, clients, and regulators are not yet aware.

Discussion questions

- What scoping actions should Security take now?
- Do you search for similar messages across the environment?
- Should enhanced monitoring or temporary payment restrictions be applied?
- What is the threshold for treating this as an enterprise campaign rather than a single fraud case?
- Who decides whether clients, partners, auditors, insurers, or regulators are notified?

Expected actions

- Search the environment for similar emails, domains, replies, and related indicators.
- Review executive mailbox activity, forwarding rules, and authentication events as applicable.
- Increase scrutiny over urgent wires, beneficiary changes, and exception approvals.
- Coordinate communications and legal review before any external statements.
- Document decisions, timelines, authorities, and evidence handling.

Facilitator notes

Use this phase to test cross-functional coordination between cyber, fraud, treasury, legal, and communications. If participants focus only on the single wire, prompt them to consider systemic exposure.

Phase 4 – Outcome, Recovery, and Reporting

Inject 4

The bank receives partial feedback from external institutions: either the transfer is frozen in time, partially recovered, or moved onward before a full hold was placed. Leadership requests a decision on communications, regulatory notification, customer impact assessment, and post-incident remediation.

What participants know at this stage

- Recovery outcome is uncertain or partial.
- Control weaknesses and exception handling gaps are now visible.
- Executive leadership wants a clear impact statement and next-step plan.
- Regulators and law enforcement may need to be engaged depending on jurisdiction and impact.

Discussion questions

- How is business impact assessed and communicated to leadership?
- What legal and regulatory obligations apply?
- How is reputational risk managed if the event becomes public?
- What immediate control changes should be made before business-as-usual resumes?
- What should go into the post-incident report and lessons-learned review?

Expected actions

- Confirm financial exposure and recovery status.
- Determine reporting obligations with Legal and Compliance.
- Brief executives with clear facts, assumptions, decisions, and residual risk.
- Implement short-term control enhancements for payment approvals and executive requests.
- Launch post-incident review and lessons-learned process.

Facilitator notes

Allow the group to discuss multiple possible endings: successful recall, partial loss, full loss, or discovery of wider targeting. This helps test resilience across different outcomes.

11. Decision Points

Key decision points for the facilitator to emphasize:

1. Whether to halt payment pending secondary verification.
 2. Whether the request qualifies as a fraud event, cyber event, or combined incident.
 3. Whether crisis management should be activated.
 4. When to initiate recall before full validation is complete.
 5. Whether to impose temporary enhanced controls on similar payments.
 6. Whether regulatory, law-enforcement, insurer, or customer notification thresholds are met.
 7. What executive message is delivered internally and externally.
-

12. Operational and Business Impacts

Operational impacts

- Disruption to high-value payment approvals

- Increased manual review of urgent transfers
- Potential delay in treasury operations
- Need for emergency coordination across multiple teams

Business impacts

- Direct financial loss or temporary liquidity effects
 - Reputational damage
 - Regulatory scrutiny over payment controls
 - Potential legal exposure
 - Reduced confidence in executive communications and approval workflows
-

13. Facilitator Guide

Suggested flow

- 10 minutes: Introduction, objectives, rules
- 10 minutes: Phase 1 discussion
- 15 minutes: Phase 2 discussion
- 15 minutes: Phase 3 discussion
- 10 minutes: Phase 4 discussion
- 10–15 minutes: Debrief and lessons learned

Facilitation tips

- Encourage role-based answers grounded in actual process.
- Ask who has authority, not just who has awareness.
- Challenge assumptions around urgency, executive privilege, and informal workarounds.
- Track where decisions depend on undocumented tribal knowledge.
- Separate what exists on paper from what would happen in practice.

Evidence prompts

Ask participants whether they would know how to quickly access:

- Email headers and message trace data
 - Payment system audit logs
 - Approval workflow records
 - Call recordings or voice verification logs
 - User activity and mailbox forwarding rules
 - Beneficiary maintenance history
-

14. Evaluation Criteria

Assess participant performance against the following areas:

- Recognition of BEC indicators
 - Adherence to payment verification controls
 - Timeliness of escalation
 - Quality of fraud recall and recovery actions
 - Preservation of evidence and documentation
 - Executive and cross-functional coordination
 - Legal and regulatory awareness
 - Quality of communications and decision-making under pressure
-

15. Debrief Questions

1. What worked well in the first 30 minutes of the scenario?
 2. Where did process ambiguity or role confusion emerge?
 3. Were fraud and cyber workflows integrated or siloed?
 4. Could the current process withstand a sophisticated executive impersonation attempt?
 5. Are exception paths too easy to invoke under pressure?
 6. How effective are current out-of-band verification controls?
 7. What immediate procedural or technical changes are needed?
 8. What long-term control, training, or governance improvements should be prioritized?
-

16. Recommended Improvement Actions

Immediate

- Reiterate mandatory out-of-band verification for urgent, confidential, and high-value transfer requests.
- Require enhanced review for new or changed beneficiaries.
- Tune email controls for executive impersonation, lookalike domains, and display-name abuse.
- Create a single fraud/cyber rapid response checklist for payment fraud events.

Near term

- Test callback procedures and approval authority verification.
- Review exception handling governance and approval evidence retention.
- Strengthen treasury fraud scenarios in training and awareness programs.
- Establish clearer criteria for crisis activation and external notification.

Longer term

- Mature anti-spoofing protections and executive communication safeguards.

- Improve transaction analytics for anomalous urgency, geography, value, and beneficiary patterns.
- Run additional exercises involving mailbox compromise, account takeover, or multi-stage BEC.

17. MITRE ATT&CK Mapping

The scenario most directly aligns to the following ATT&CK techniques:

ATT&CK tactic	Technique	ID	Relevance to scenario
Initial Access	Phishing	T1566	The scenario centers on a targeted fraudulent email used for social engineering and deceptive access to business process trust.
Initial Access	Trusted Relationship	T1199	The actor abuses the inherent trust placed in executive-to-finance communications to influence transaction approval.

Supplemental notes

- This scenario is primarily a **social engineering and business process compromise** exercise rather than a malware-centric intrusion.
- Depending on how facilitators choose to extend the scenario, it may also touch mailbox abuse, valid account misuse, or email collection, but those are not explicitly established by the source STIX.

18. Optional Variant Paths

Facilitators may optionally introduce one of the following variants:

- **Variant A: Mailbox compromise confirmed** – investigators discover the CFO’s mailbox forwarding rules were altered.
- **Variant B: Multiple targets** – similar messages were sent to several approvers in finance and treasury.
- **Variant C: Partial recovery only** – funds moved through additional accounts before the recall landed.
- **Variant D: Media inquiry** – a journalist contacts communications asking whether the bank lost funds to an executive impersonation fraud.

19. Closing

This exercise is intended to help participants rehearse a realistic, high-pressure fraud scenario that sits at the intersection of cyber security, operational risk, treasury controls, legal response, and executive decision-making. The quality of the response depends less on technical complexity than on disciplined verification,

rapid escalation, coordinated action, and a willingness to challenge urgency when normal controls are being bypassed.